

Como se ataca Active Directory

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

Active Directory es el directorio que gestiona usuarios, equipos y permisos de una red Windows. Atacarlo no va de un exploit puntual, sino de conseguir una identidad (un usuario) y usar sus permisos para conseguir otra mas fuerte, repitiendo hasta llegar a Domain Admin o al hash de krbtgt.

AD esta hecho de relaciones de confianza (grupos, delegaciones, ACLs, sesiones). Cada credencial abre nuevas relaciones que explotar. Por eso la mentalidad es distinta: importa mas el grafo de permisos (bloodhound lo mapea) que la version de un servicio.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

En cuanto el recon confirme un DC (puertos 88 Kerberos + 389 LDAP + 445). El trabajo previo imprescindible es resolver nombres y hora, o Kerberos falla con errores confusos.

Cómo identificarla

- Puertos 88, 389, 445, 636, 3268 abiertos en el mismo host.
- nmap/enum filtra un nombre de dominio (algo.local) y el hostname del DC.
- Errores de 'clock skew' al usar herramientas: tu reloj no cuadra con el DC.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Escanea los puertos tipicos de DC y confirma que 88 (Kerberos) responde.

Evidencia esperada: 88+389+445 abiertos en el mismo host, y los scripts de nmap/enum filtran el nombre del dominio.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
nmap -sC -sV -Pn -p 53,88,135,139,389,445,464,636,3268,5985 $IP
```

Objetivo y contexto: Escanea los puertos típicos de un DC de una vez. La combinación 88+389+445 confirma que estas ante un dominio y no una máquina suelta.

Resultado esperado: Puerto 88 abierto = DC. Los scripts LDAP/SMB filtran el nombre del dominio y del DC: anotalos para /etc/hosts antes de seguir.

Anatomía de los payloads

La primera prueba es `nmap -sC -sV -Pn -p 53,88,135,139,389,445,464,636,3268,5985 $IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

88+389+445 abiertos en el mismo host, y los scripts de `nmap/enum` filtran el nombre del dominio.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Prepara nombres (/etc/hosts) y sincroniza la hora con el DC.
- Consigue el primer usuario: `enum de SMB (smb-enum)`, `rid-brute` y `password spraying` controlado.
- Saca hashes crackeables por Kerberos (`asrep-kерberoast`) y mapea permisos con `bloodhound`.
- Extrae hashes del objetivo y autentica con `ntlm-pth` hasta Domain Admin.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El objetivo es una máquina Windows standalone sin dominio (no hay 88/389 abiertos).
- No tienes ninguna vía de conseguir un primer usuario (sin acceso anónimo, sin usuarios enumerables).
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

En AD no explotas una maquina: transformas una identidad en mas permisos, en cadena, hasta Domain Admin. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (ad-modelo)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.